

Prompt Log

Prompt v1 — Strict Rule-Based Analyzer

Core Characteristics

- Strong scope constraints (code-only, no assumptions)
- OWASP 2025 category enforcement
- Aggressive false-positive suppression
- Mandatory self-critique pass
- Deterministic JSON-only output
- Requires mitigation field
- No examples
- No confidence scoring
- No structured line numbers

Strengths

- Very low hallucination risk
- Strong exploitability discipline
- Automation-friendly JSON enforcement

Limitations

- No behavioral anchoring → output variance possible
- No confidence score → hard to filter at scale
- No structured line references → weaker IDE/tool integration
- Mitigation requirement can introduce speculative fixes

Prompt v2 — Calibrated & Production-Ready Analyzer

Adds to v1

- Few-shot examples (positive + suppression case)
 - `risk_summary` field (developer-friendly)
 - `line_start` / `line_end` (mandatory)
 - `confidence` score
 - Explicit safe-query suppression example
 - Removed mitigation requirement
-

What Improved

1. Determinism ↑

Few-shot examples anchor:

- What qualifies as real
- What must be suppressed

Reduces drift across runs.

2. False Positives ↓

Safe example clarifies “risky API used safely.”

Stronger suppression calibration.

3. Scalability ↑

Confidence score enables:

- Automated threshold filtering
- Ranking
- Batch triage

4. Traceability ↑

Line numbers enable:

- IDE integration
- Code highlighting

- Faster review workflows

5. Developer Usability ↑

`risk_summary` improves readability in dashboards.

Net Result

Dimension	v1	v2
Precision	High	Very High
Determinism	Medium-High	Very High
False Positives	Low	Lower
Automation Readiness	High	Very High
Developer Consumption	Moderate	High

Final Conclusion

v1 = Strict policy engine.

v2 = Strict policy engine + behavioral calibration + automation optimization.

v2 is more scalable, more deterministic, and better suited for high-volume production scanning without sacrificing exploitability rigor.